TOSCANA DIAGNOSTICA

info@toscanadiagnostica.it
toscanadiagnostica@pec.it
www.toscanadiagnostica.it

Dichiarazione Applicabilità ISO27001

TD-SGI-MOD011_00

1. Legenda e criteri

Applicabile (Appl.): Sì = il controllo è applicabile al contesto TD; No = non applicabile (con giustificazione). Stato: I = Implementato; PI = Parzialmente implementato; P = Pianificato; NA = Non applicabile. Rif. SGI: documento del SGI che attua il controllo. Il riesame è annuale, nell'ambito del Riesame della Direzione (TD-SGI-PRO002).

Cl.	Controllo	Appl.	Stato	Rif. SGI	Giustificazione / Note
A.5 – CONTROLLI ORGANIZZATIVI (37 controlli)					
5.1	Politiche per la sicurezza delle informazioni	**Sì**	I	POL001, PRO016	Politica Integrata e procedura sicurezza SI
5.2	Ruoli e responsabilità per la sicurezza	**Sì**	I	PRO016 Sez.14, REG003	RACI e designazione AdS
5.3	Separazione dei compiti	**Sì**	I	PRO016 Sez.5	RBAC per ruolo; separazione IT/utente
5.4	Responsabilità della direzione	**Sì**	I	POL001, MAN001	Impegno AD nel SGI
5.5	Contatti con le autorità	**Sì**	I	PRO019 Sez.7	Contatti Garante, CSIRT, forze dell'ordine
5.6	Contatti con gruppi specialistici	**Sì**	I	PRO019 Sez.7	Fornitori SaaS, WIND, community CERT
5.7	Threat intelligence	**Sì**	PI	PRO016 Sez.6	EDR + Microsoft Defender; da strutturare raccolta threat intel
5.8	Sicurezza nella gestione dei progetti	**Sì**	I	PRO018	Change management con analisi impatto sicurezza
5.9	Inventario delle informazioni e degli asset	**Sì**	I	PRO016 Sez.4	Inventario asset aggiornato
5.10	Uso accettabile delle informazioni e degli asset	**Sì**	I	PRO016 Sez.6	Regole postazioni; divieto installazione; USB
5.11	Restituzione degli asset	**Sì**	I	PRO016 Sez.5.2	Disattivazione e restituzione alla cessazione
5.12	Classificazione delle informazioni	**Sì**	I	PRO001, PRO016	Classificazione: Pubblico, Interno, Riservato
5.13	Etichettatura delle informazioni	**Sì**	PI	PRO016	Classificazione indicata su documenti SGI; da estendere
5.14	Trasferimento delle informazioni	**Sì**	I	PRO016 Sez.9	TLS, cifratura email OME, SFTP per dati sanitari
5.15	Controllo degli accessi	**Sì**	I	PRO016 Sez.5	MFA, RBAC, Azure AD, revisione semestrale
5.16	Gestione delle identità	**Sì**	I	PRO016 Sez.5.2	Ciclo vita utenze: creazione, modifica, disattivazione
5.17	Informazioni di autenticazione	**Sì**	I	PRO016 Sez.5.1	Password 12+ car., scadenza 90gg, MFA
5.18	Diritti di accesso	**Sì**	I	PRO016 Sez.5, REG003	Profili RBAC; revisione semestrale; minimo privilegio
5.19	Sicurezza nelle relazioni con i fornitori	**Sì**	I	PRO016 Sez.8, PRO006	Shared responsibility; DPA art.28; verifica annuale
5.20	Sicurezza negli accordi con i fornitori	**Sì**	I	PRO016 Sez.8	SLA, DPA, clausole sicurezza nei contratti SaaS
5.21	Gestione della sicurezza nella supply chain ICT	**Sì**	I	PRO016 Sez.8, PRO006	Due diligence fornitori; certificazioni ISO 27001
5.22	Monitoraggio, revisione e change dei servizi dei fornitori	**Sì**	I	PRO018 Sez.5	Gestione rilasci SaaS; revisione SLA annuale
5.23	Sicurezza per i servizi cloud	**Sì**	I	PRO016 Sez.8	ISO 27017/27018; data residency EU; cifratura
5.24	Pianificazione della gestione degli incidenti	**Sì**	I	PRO019	Procedura completa con 7 fasi, escalation, fallback
5.25	Valutazione e decisione sugli eventi	**Sì**	I	PRO019 Sez.4.2	Triage P1-P4 con criteri e tempi
5.26	Risposta agli incidenti	**Sì**	I	PRO019 Sez.4.3-4.5	Contenimento, indagine, ripristino
5.27	Apprendimento dagli incidenti	**Sì**	I	PRO019 Sez.4.7	Lesson learned e azioni correttive
5.28	Raccolta delle evidenze	**Sì**	I	PRO019 Sez.4.4	Preservazione log e evidenze forensi
5.29	Sicurezza durante le interruzioni	**Sì**	I	PRO016 Sez.10, PRO019 Sez.6	BC/DR; procedure fallback manuali
5.30	Prontezza ICT per la continuità operativa	**Sì**	I	PRO016 Sez.10	RPO/RTO per sistema; test annuale DR
5.31	Requisiti legali, statutari, regolamentari e contrattuali	**Sì**	I	PRO016 Sez.2, PRO019 Sez.2	GDPR, NIS 2, Provv. Garante AdS
5.32	Diritti di proprietà intellettuale	**Sì**	I	PRO016 Sez.4	Inventario licenze software
5.33	Protezione delle registrazioni	**Sì**	I	PRO016 Sez.9	Retention policy; cifratura; backup
5.34	Privacy e protezione dei dati personali	**Sì**	I	PRO016 Sez.9	GDPR; DPA; minimizzazione; pseudonimizzazione
5.35	Revisione indipendente della sicurezza	**Sì**	PI	PRO016 Sez.13	Audit interno annuale; vulnerability assessment; audit esterno da pianificare
5.36	Conformità alle politiche, regole e standard	**Sì**	I	PRO016 Sez.13	Audit e monitoraggio continuo
5.37	Procedure operative documentate	**Sì**	I	PRO016-019, REG003	Corpus procedurale Area 08 completo

Cl.	Controllo	Appl.	Stato	Rif. SGI	Giustificazione / Note
A.6 – CONTROLLI SULLE PERSONE (8 controlli)					
6.1	Screening	**Sì**	I	PRO006	Verifica referenze e precedenti in fase di assunzione
6.2	Termini e condizioni di impiego	**Sì**	I	REG003 Sez.9	Clausole riservatezza nel contratto; NDA
6.3	Consapevolezza, istruzione e formazione	**Sì**	I	PRO016 Sez.12	Induction, aggiornamento annuale, phishing simulato, formazione AdS
6.4	Processo disciplinare	**Sì**	I	CCNL, Regolamento interno	Azioni disciplinari per violazioni sicurezza
6.5	Responsabilità dopo la cessazione	**Sì**	I	REG003 Sez.9-10	Riservatezza post-cessazione; disattivazione utenze
6.6	Accordi di riservatezza	**Sì**	I	REG003 Sez.9	NDA; clausole nei contratti e nei DPA
6.7	Lavoro da remoto	**Sì**	I	PRO016 Sez.5.1	VPN con autenticazione forte; MFA; BitLocker su laptop
6.8	Segnalazione degli eventi	**Sì**	I	PRO019 Sez.4.1, REG003	Obbligo segnalazione anomalie; canale IT

Cl.	Controllo	Appl.	Stato	Rif. SGI	Giustificazione / Note
A.7 – CONTROLLI FISICI (14 controlli)					
7.1	Perimetri di sicurezza fisica	**Sì**	I	Sedi operative	Accesso controllato a tutte le sedi; reception/accettazione
7.2	Controlli di ingresso fisico	**Sì**	I	Sedi operative	Badge, chiavi, controllo accessi aree server/rete
7.3	Messa in sicurezza di uffici, locali e strutture	**Sì**	I	Sedi operative	Armadi chiusi per documentazione; aree riservate IT
7.4	Monitoraggio della sicurezza fisica	**Sì**	PI	Sedi operative	Videosorveglianza su sedi principali; da estendere
7.5	Protezione contro minacce fisiche e ambientali	**Sì**	I	PRO009, PRO016 Sez.10	Presidi emergenza; BC/DR per rischi fisici
7.6	Lavoro in aree sicure	**Sì**	I	Sedi operative	Accesso limitato a locali tecnici; registro accessi
7.7	Scrivania e schermo puliti	**Sì**	I	PRO016 Sez.6	Blocco schermo 5 min; clean desk policy
7.8	Collocazione e protezione delle apparecchiature	**Sì**	I	PRO016 Sez.3-4	Apparati rete in armadi rack chiusi; UPS
7.9	Sicurezza degli asset fuori sede	**Sì**	I	PRO016 Sez.6	BitLocker laptop; VPN; cifratura dati
7.10	Supporti di memorizzazione	**Sì**	I	PRO016 Sez.6	USB controllate; cancellazione sicura alla dismissione
7.11	Servizi di supporto (utilities)	**Sì**	I	PRO016 Sez.10	UPS; WIND backup 10Gb; generatore emergenza
7.12	Sicurezza del cablaggio	**Sì**	I	WIND	Cablaggio strutturato gestito da WIND; armadi chiusi
7.13	Manutenzione delle apparecchiature	**Sì**	I	PRO016 Sez.4, WIND	Manutenzione programmata apparati rete; SLA WIND
7.14	Dismissione o riutilizzo sicuro delle apparecchiature	**Sì**	I	PRO012, PRO016	RAEE con wipe dati ISO 27001; cancellazione sicura

Cl.	Controllo	Appl.	Stato	Rif. SGI	Giustificazione / Note
A.8 – CONTROLLI TECNOLOGICI (34 controlli)					
8.1	Dispositivi endpoint dell'utente	**Sì**	I	PRO016 Sez.6	Windows 10/11; EDR; BitLocker; patch 7gg; no admin
8.2	Diritti di accesso privilegiato	**Sì**	I	REG003	Designazione AdS; password 16+ car.; revisione annuale log
8.3	Restrizione dell'accesso alle informazioni	**Sì**	I	PRO016 Sez.5	RBAC; accesso dati sanitari solo personale autorizzato
8.4	Accesso al codice sorgente	**No**	NA	–	TD non sviluppa software; sistemi SaaS di terze parti
8.5	Autenticazione sicura	**Sì**	I	PRO016 Sez.5.1	MFA Azure AD; password complesse; SSO ove possibile
8.6	Gestione della capacità	**Sì**	I	PRO016 Sez.8	Scalabilità cloud SaaS; monitoraggio WIND banda
8.7	Protezione contro il malware	**Sì**	I	PRO016 Sez.6	EDR centralizzato; scansione real-time; Defender M365
8.8	Gestione delle vulnerabilità tecniche	**Sì**	I	PRO016 Sez.6,13	Patch 7gg; vulnerability assessment annuale
8.9	Gestione della configurazione	**Sì**	I	PRO018	Change management; baseline configurazioni
8.10	Cancellazione delle informazioni	**Sì**	I	PRO016 Sez.9	Retention policy; cancellazione sicura; wipe RAEE
8.11	Mascheramento dei dati	**Sì**	PI	PRO016 Sez.9	Pseudonimizzazione in analytics; da estendere a test
8.12	Prevenzione della fuga di dati	**Sì**	PI	PRO016 Sez.6	Filtro allegati M365; USB controllate; DLP da implementare
8.13	Backup delle informazioni	**Sì**	I	PRO016 Sez.10	Backup cloud SaaS; RPO definiti per sistema
8.14	Ridondanza delle strutture di elaborazione	**Sì**	I	PRO016 Sez.10	Cloud SaaS geo-ridondante; WIND 10Gb+10Gb
8.15	Logging	**Sì**	I	REG003 Sez.7, PRO016 Sez.13	Access log AdS 6 mesi; log applicativi; log firewall
8.16	Attività di monitoraggio	**Sì**	I	PRO016 Sez.7,13	WIND monitoraggio 24/7; EDR; IPS/IDS
8.17	Sincronizzazione degli orologi	**Sì**	I	PRO016, REG003	NTP su tutti i sistemi; timestamp ISO 8601
8.18	Uso di programmi di utilità privilegiati	**Sì**	I	PRO016 Sez.6, REG003	No admin locale; strumenti solo per AdS autorizzati
8.19	Installazione di software sui sistemi operativi	**Sì**	I	PRO016 Sez.6	Divieto installazione utente; solo IT autorizzato
8.20	Sicurezza delle reti	**Sì**	I	PRO016 Sez.7	NGFW; segmentazione VLAN; IPS/IDS; WIND gestione
8.21	Sicurezza dei servizi di rete	**Sì**	I	PRO016 Sez.7	SLA WIND; QoS VoIP; monitoraggio 24/7
8.22	Segregazione delle reti	**Sì**	I	PRO016 Sez.7	VLAN: clinica, admin, ospiti, management
8.23	Filtraggio web	**Sì**	I	PRO016 Sez.6	Filtro contenuti; blocco categorie a rischio
8.24	Uso della crittografia	**Sì**	I	PRO016 Sez.9	AES-256 at-rest; TLS 1.2+ in-transit; BitLocker; OME
8.25	Ciclo di vita dello sviluppo sicuro	**No**	NA	–	TD non sviluppa software; SaaS di terze parti
8.26	Requisiti di sicurezza delle applicazioni	**Sì**	I	PRO016 Sez.8	Verifica certificazioni fornitori SaaS; test accettazione
8.27	Architettura di sistema sicura e principi di ingegneria	**Sì**	I	PRO016 Sez.3	Architettura cloud-first; defense in depth; zero trust
8.28	Codifica sicura	**No**	NA	–	TD non sviluppa software
8.29	Test di sicurezza nello sviluppo e nell'accettazione	**Sì**	I	PRO018 Sez.4.4	Test funzionale, regressione, sicurezza, UAT
8.30	Sviluppo in outsourcing	**Sì**	I	PRO016 Sez.8	Fornitori SaaS responsabili dello sviluppo; verifica SLA
8.31	Separazione degli ambienti	**Sì**	PI	PRO018 Sez.4.4	Staging ove disponibile dai fornitori SaaS; da verificare
8.32	Gestione delle modifiche	**Sì**	I	PRO018	Procedura change management completa
8.33	Informazioni di test	**Sì**	PI	PRO018	Dati di test pseudonimizzati; da formalizzare policy
8.34	Protezione dei sistemi durante i test di audit	**Sì**	I	PRO016 Sez.13	Vulnerability assessment pianificato; impatto minimizzato

info@toscanadiagnostica.it
toscanadiagnostica@pec.it
www.toscanadiagnostica.it

2. Sintesi della dichiarazione di applicabilità

Tema	Totale controlli	Applicabili	Implementati (I)	PI / P
A.5 Organizzativi	37	37	35	2 PI
A.6 Persone	8	8	8	0
A.7 Fisici	14	14	13	1 PI
A.8 Tecnologici	34	31	26	5 PI
TOTALE	**93**	**90**	**82**	**8 PI**

Controlli non applicabili (3): cl. 8.4 (accesso codice sorgente), 8.25 (ciclo sviluppo sicuro), 8.28 (codifica sicura). Giustificazione: Toscana Diagnostica non sviluppa software; tutti i sistemi applicativi sono erogati in modalità SaaS da fornitori terzi.

Controlli parzialmente implementati (8): cl. 5.7 (threat intelligence), 5.13 (etichettatura), 5.35 (revisione indipendente), 7.4 (monitoraggio fisico), 8.11 (mascheramento dati), 8.12 (DLP), 8.31 (separazione ambienti), 8.33 (informazioni di test). Azioni di completamento pianificate nel Piano Obiettivi SGI (TD-SGI-PLN001).

3. Storico delle revisioni

Rev.	Data	Descrizione modifiche	Approvazione
00	12/04/2026	Prima emissione	Francesco Epifani